

Dependency Risk Scoring Report

Project: com.demo.supplychain:vulnerable-invoice-service:1.0.0 · **Generated:** 2026-06-23 · **Commit:** 61ed8c3 · **Scanner:** OWASP
Dependency-Check 12.2.2 (NVD data 2026-06-13)

Executive Summary

Band	Count
CRITICAL	1
HIGH	6
MEDIUM	3
LOW	0

Total CVEs identified: 75 across 9 resolvable dependencies **Supply-chain alerts:** 2 (1 typosquat + 1 untrusted HTTP repository)
License violations: 1 (GPL-2.0 copyleft conflict)

Scoring formula: $\text{risk_score} = 0.5 * \text{cve_severity} + 0.3 * \text{exposure} + 0.2 * \text{business_criticality}$ A dependency carrying any CRITICAL CVE is floored to band HIGH regardless of weighted score. A supply-chain threat (typosquat) is assigned band CRITICAL by policy.

Ranked Remediation Backlog

#	Coordinate	Version	Band	Risk Score	Top CVE	Fix Version
1	com.fastxml.jackson.core:jackson-databind	2.9.8	CRITICAL	—	Typosquat (REMOVE)	Remove
2	org.apache.logging.log4j:log4j-core	2.14.1	HIGH	7.8	CVE-2021-44228 (10.0)	2.26.0
3	com.fasterxml.jackson.core:jackson-databind	2.9.8	HIGH	7.8	CVE-2019-14379 (9.8)	2.18.4
4	mysql:mysql-connector-java	8.0.30	HIGH	7.25	CVE-2023-22102 (8.3)	8.0.31
5	org.apache.logging.log4j:log4j-api	2.14.1	HIGH	6.8	CVE-2026-34479 (7.5)	2.26.0
6	com.google.protobuf:protobuf-java	3.19.4	HIGH	6.4	CVE-2024-7254 (7.5)	3.25.5
7	com.google.guava:guava	24.1.1-jre	HIGH	6.3	CVE-2023-2976 (7.1)	32.0.0-jre
8	com.fasterxml.jackson.core:jackson-annotations	2.9.0	MEDIUM	5.15	CVE-2018-1000873 (6.5)	2.9.8
9	org.apache.commons:commons-lang3	3.4	MEDIUM	5.15	CVE-2025-48924 (5.3)	3.17.0
10	commons-io:commons-io	2.4	MEDIUM	5.15	CVE-2021-29425 (4.8)	2.14.0

Component Score Detail

Coordinate	CVE Severity	Exposure	Business Criticality	Risk Score	Band
------------	--------------	----------	----------------------	------------	------

com.fastxml...:jackson-databind:2.9.8	0.0 (typosquat)	8.0	5.0	3.4	CRITICAL
log4j-core:2.14.1	10.0 (cap; 8 CVEs)	8.0	2.0	7.8	HIGH
jackson-databind:2.9.8	10.0 (cap; 54 CVEs)	8.0	2.0	7.8	HIGH
mysql-connector-java:8.0.30	8.3	7.0	5.0	7.25	HIGH
log4j-api:2.14.1	8.0 (density +0.5)	8.0	2.0	6.8	HIGH
protobuf-java:3.19.4	9.0 (density +1.5)	5.0	2.0	6.4	HIGH
guava:24.1.1-jre	7.6 (density +0.5)	7.0	2.0	6.3	HIGH
jackson-annotations:2.9.0	6.5	5.0	2.0	5.15	MEDIUM
commons-lang3:3.4	5.3	7.0	2.0	5.15	MEDIUM
commons-io:2.4	5.3 (density +0.5)	7.0	2.0	5.15	MEDIUM

Supply-Chain Alerts

Alert	Type	Band	Action
com.fastxml.jackson.core:jackson-databind:2.9.8	TYPOSQUATTING	CRITICAL	Remove from pom.xml immediately
http://insecure-mirror.example.net/maven2	UNTRUSTED HTTP REPO	HIGH	Remove repository declaration; use HTTPS only

License Risks

Dependency	License	Issue	Action
mysql:mysql-connector-java:8.0.30	GPL-2.0	Copyleft conflict with permissive project	Obtain Oracle commercial license or switch to MariaDB Connector/J (LGPL-2.1)

Outdated Dependencies

Dependency	Current	Latest	Gap
log4j-core / log4j-api	2.14.1	2.26.0	12 minor versions
jackson-databind	2.9.8	2.18.4	9 minor versions
guava	24.1.1-jre	33.4.8-jre	9 major versions
commons-io	2.4	2.18.0	14 minor versions
commons-lang3	3.4	3.20.0	16 minor versions
mysql-connector-java	8.0.30	8.0.33	3 patch versions

Recommended Remediation Order

Priority	Action	Effort
1	Remove typosquatted <code>com.fastxml.jackson.core:jackson-databind</code> from pom.xml	Minutes
2	Remove untrusted HTTP repository declaration from pom.xml	Minutes

3	Upgrade <code>log4j-core</code> + <code>log4j-api</code> 2.14.1 → 2.26.0 (Log4Shell: CISA KEV)	Hours
4	Upgrade <code>jackson-databind</code> 2.9.8 → 2.18.4 (54 CVEs including 14 CRITICAL)	Hours
5	Upgrade <code>mysql-connector-java</code> 8.0.30 → 8.0.31; evaluate GPL-2.0 license	Hours
6	Upgrade <code>guava</code> 24.1.1-jre → 32.0.0-jre	Hours
7	Upgrade <code>commons-io</code> 2.4 → 2.14.0 + <code>commons-lang3</code> 3.4 → 3.17.0	Hours

Machine-readable source: `depscan-risk-report.json` . Ready for the **Auto-Remediation Skill** (Stage 3) and the **PR Validation Agent** (Stage 4). Generated by the *Dependency & Supply-Chain Plugin* — Stage 2.